

Network Security — Chapter 4

Last-Minute Revision | Mnemonics + Diagrams + Dev Examples

The Story: Security has rules (CIA + more), villains attack them (I'M FI), we defend with armor (TLS, IPSec), gates (Firewalls, IPS/IDS), and tunnels (VPNs). WPA secures Wi-Fi.

Master Mnemonic Cheatsheet

Mnemonic	Stands For	Topic
CIA-AAN-Z	Confidentiality, Integrity, Availability + Auth, Authz, Non-repudiation, Zero Trust	7 Security Principles
I'M FI	Interception, Modification, Fabrication, Interruption	4 Threat Categories
HRA	Handshake, Record, Alert protocols	TLS Architecture
CSKSF	Client Hello / Server Hello+Cert / Key Exchange / Session Keys / Finished	TLS Workflow
AESI	AH, ESP, SA, IKE	IPSec Components
Know/Are/Have	Password / Biometric / Token	Auth Factors
DMRA-R	DAC, MAC, RBAC, ABAC, RuBAC	Access Control Models
VPA	Volumetric, Protocol, Application-layer	DoS Types
ADHE	ARP, DNS, HTTPS-strip, Evil Twin	MITM Techniques
AID-TDU	App-aware, IPS, DPI, Threat-intel, Decryption, User-ID	NGFW Features
ADDR	Alert, Drop, Deny, Reset	IPS Actions
ETM	Encryption, Tunneling, Masking IP	How VPNs Work

1. Security Principles & 4 Threats

1.1 The 7 Security Principles

★ **HOOK: CIA-AAN-Z** — bank analogy: curtains (C), tamper-proof balance (I), 24/7 ATM (A), ID at entry (Auth), only manager opens vault (Authz), signed slip (Non-repudiation), even manager re-checked (Zero Trust).

Principle	Meaning
Confidentiality	Only authorized users access data (encrypt secrets)
Integrity	Data not altered without permission
Availability	System reliably reachable when needed
Authentication	Verify WHO you are (login, ID)
Authorization	Limit WHAT you can do (roles)
Non-repudiation	Can't deny actions later (signed receipt)
Zero Trust	'Never trust, always verify' — even insiders

1.2 Network Security Protocols

Protocol	Purpose
SSL/TLS	Encrypts web traffic (HTTPS)
IPSec	Secures IP packets (used in VPNs)
SSH	Secure remote command-line access
SFTP	Secure file transfer (built on SSH)
SNMP	Network device monitoring/management
ICMP	Diagnostics (ping); must be secured (Ping-of-Death, ICMP flood)

1.3 The 4 Threats — I'M FI (Delivery Man Analogy)

Imagine a courier delivering a package from **Service** → **User**. The villain can do 4 different things:

Interception (PASSIVE) — spy reads but lets it through

```
[Service] -----Original Message-----> [User] (gets it OK)
      :
      v
    [Intruder]  <-- secretly listens / sniffs
```

Breaks: **CONFIDENTIALITY**

Examples: Eavesdropping, Packet Sniffing, MITM (listening phase)

Mitigation: Encrypt, Trusted WiFi, Software updates

Interruption (ACTIVE) — package destroyed, blocked

```
[Service] -----Original Message---X [User] (NEVER gets it)
      :
      v
    [Intruder]  -- DoS / malware / hardware damage
```

Breaks: **AVAILABILITY**

Examples: DoS, Malware (viruses, trojans), Hardware disruption

Mitigation: Firewalls, System backups, CDN, Cloud

Modification (ACTIVE) — package opened, changed, forwarded

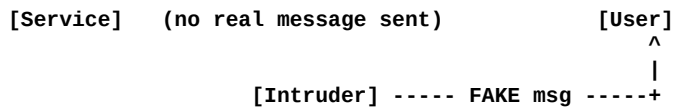
```
[Service] -- msg --> [Intruder] -- TAMPERED msg --> [User] (gets fake)
                        ^
                        |
                    changes content
```

Breaks: **INTEGRITY** (+ Availability if config files changed)

Examples: MITM (active phase), Cross-Site Scripting (XSS)

Mitigation: IDS, Data Encryption, Access Controls

Fabrication (ACTIVE) — fake package, no original



Breaks: AUTHENTICATION (+ Availability via traffic floods)
Examples: Spoofing, SQL Injection, Phishing, Replay attacks
Mitigation: Digital signatures, Encryption, Firewalls

1.4 THE GOLDEN TABLE (memorize this for sure)

Threat	Type	CIA Broken	Examples	Mitigation
Interception	PASSIVE	Confidentiality	Eavesdrop, Sniff, Pwd attacks	Encrypt, Trusted WiFi
Interruption	Active	Availability	DoS, Malware, HW damage	Firewall, Backup, CDN
Modification	Active	Integrity (+Avail)	MITM, XSS	IDS, Encrypt, Access Ctrl
Fabrication	Active	Auth (+Avail)	Spoof, SQLi, Phishing, Replay	Digital sig, Firewall

KEY INSIGHT: Only Interception is PASSIVE (it just listens). The other 3 are ACTIVE (they DO something to the data).

Yap: 'The four threat categories — Interception, Modification, Fabrication, Interruption — map cleanly to the CIA triad. Interception, the only passive attack, threatens confidentiality through techniques like packet sniffing. The other three are active: Interruption (DoS, malware) targets availability, Modification (MITM, XSS) targets integrity, and Fabrication (spoofing, SQLi, phishing) targets authentication.'

2. Securing Communication: TLS, HTTPS, IPSec

2.1 The Layer Cake (where each lives)

```
+-----+
| Application Layer | <-- HTTPS lives here
+-----+
| TLS sits BETWEEN these | <-- SSL/TLS
+-----+
| Transport Layer (TCP) |
+-----+
| Network Layer (IP) | <-- IPSec lives here (L3)
+-----+
```

Lower the layer = more it protects.

IPSec @ L3 protects EVERYTHING above. TLS @ top protects only app data.

2.2 SSL/TLS — Secure Sockets Layer / Transport Layer Security

What: Secures network communication, mainly web. SSL=old, TLS=modern.

Layer: Between Transport (TCP) and Application Layer.

★ **HOOK: Architecture = HRA (Hurrah! Secure!): Handshake, Record, Alert.**

Component	Role
Handshake	Authenticates parties + negotiates encryption keys (the meet-and-greet)
Record	Fragments, compresses, MACs, encrypts, transmits data (the actual work)
Alert	Handles errors and connection closures (warning system)

TLS Workflow (5 steps) — CSKSF

```
CLIENT                                SERVER
|----- (1) Client Hello: TLS versions+ciphers ---->|
|<---- (2) Server Hello + Certificate (pubkey) ---|
|----- (3) Key Exchange: pre-master secret ----->|
|          (encrypted with server's public key)      |
| (4) Both derive SYMMETRIC session keys from        |
| pre-master secret (asym -> sym switch)             |
|==== (5) Finished: encrypted comms BEGIN =====>|
|<=====|
```

Dev: When you do `fetch('https://api.openai.com/...')`, the ~100ms before your request actually goes is the TLS handshake. `SSL_ERROR_BAD_CERT` in your terminal = the Alert Protocol crying. RWA Mind: when WhatsApp bot sends docs to your backend or DigiLocker API returns Aadhaar data, the entire exchange is wrapped in TLS — without it, packet sniffers read it in plaintext.

2.3 HTTPS = HTTP + SSL/TLS

Not a separate protocol — just HTTP riding on TLS.

Layer: Application | **Port:** 443 (HTTP=80) | **CA:** Certificate Authority issues certs (Let's Encrypt, DigiCert)

Workflow: (1) Connection Request → (2) TLS Handshake → (3) Secure Transmission via Record Protocol

Dev: Padlock icon in browser = HTTPS active + valid cert. Vercel/Netlify auto-provision Let's Encrypt certs on deploy. 'Your connection is not private' = expired/self-signed/untrusted CA.

2.4 IPSec — Internet Protocol Security

What: Suite of protocols securing IP communication by authenticating + encrypting each packet.

Layer: Network Layer (Layer 3) — deeper than TLS, protects ALL IP traffic.

★ **HOOK: Architecture = AESI (sounds like 'Easy'). AH = Auth only (no E for encrypt). ESP = Everything Secure Package.**

Component	Role
AH (Authentication Header)	Integrity + authentication, NO encryption
ESP (Encapsulating Security Payload)	Confidentiality (encryption) + auth + integrity — the full meal

3. Authentication & Access Control

3.1 Authentication Mechanisms

★ **HOOK: Something you KNOW / ARE / HAVE — classic InfoSec framework**

Factor	What it is	Examples
KNOW	Knowledge-based	Passwords, PINs, security questions
ARE	Biometric / biological	Fingerprint, Face ID, retina, voice
HAVE	Possession-based	OTP token, phone (SMS), YubiKey hardware key

2FA = combines TWO DIFFERENT factors. Two passwords ≠ 2FA. Password + OTP = 2FA.

Dev: GitHub login = pwd (know) + TOTP from Google Authenticator (have). iPhone = Face ID (are) + passcode (know). Banking = pwd + SMS OTP + fingerprint = MFA. Aadhaar eKYC = biometric + OTP. Modern WebAuthn / Passkeys = device biometric + crypto key.

3.2 Access Control Models

★ **HOOK: DMRA-R: DAC, MAC, RBAC, ABAC, RuBAC. Restaurant analogy locks all 5.**

Model	Decision Based On	Use Case
DAC (Discretionary)	Resource OWNER decides	Small teams, Google Drive sharing, Linux chmod
MAC (Mandatory)	Central authority + security labels	Government / military (SELinux, classified data)
RBAC (Role-Based)	Job roles within organization	Enterprises (AWS IAM roles, GitHub teams)
ABAC (Attribute-Based)	Dynamic user+resource+env attributes	Modern cloud / contextual policies
RuBAC (Rule-Based)	Predefined rules (e.g. time-of-day)	Firewall rules, time-window restrictions

Dev: DAC = Google Drive sharing, chmod 644. MAC = SELinux, iOS app sandboxing. RBAC = AWS IAM (admin/dev/read-only), GitHub teams, Postgres roles. ABAC = AWS IAM with conditions ('if region=us-east-1 AND tag=prod'). RuBAC = Cloudflare WAF rules, 'no Friday deploys' CI rule.

Dev: RWA Mind use case: DAC = each user controls who views their asset docs. RBAC = SME admin can invite team; viewers read only. ABAC = 'show insurance docs IF user is owner AND doc not expired AND request from verified DigiLocker session'.

Yap: 'DAC delegates to resource owners (Google Drive). MAC centralizes via security labels (military). RBAC ties permissions to roles (AWS IAM, GitHub teams). ABAC is most expressive, evaluating user, resource, and environment attributes — useful for cloud systems where time, location, device matter.'

4. Network-Based Attacks

4.1 Attack Overview — Mapped to I'M FI

Attack	Maps to I'M FI
DoS / DDoS, Malware, Ransomware	Interruption
Packet Sniffing, MITM (listening)	Interception
MITM (active), XSS	Modification
IP Spoofing, DNS Spoofing, SQLi, Phishing	Fabrication

4.2 DoS — Denial of Service

Definition: Overwhelm server with requests → legitimate users can't reach it.

Pizza shop analogy: attacker calls and orders 10,000 pizzas — phone jammed, real customers can't get through.

★ **HOOK: 3 types = VPA: Volumetric, Protocol, Application-layer (each higher floor sneakier)**

Type	Targets	Examples
Volumetric	Bandwidth (flood the pipe)	UDP Flood, ICMP/Ping Flood
Protocol	Server resources / connection tables	SYN Flood, Ping of Death, Smurf
Application-Layer	Specific app vulnerabilities (L7)	HTTP Flood, Slowloris, R.U.D.Y.

SYN Flood (the classic exam Q)

Normal TCP 3-way handshake:

```
CLIENT --SYN-->    SERVER
CLIENT <-SYN-ACK--  SERVER
CLIENT --ACK-->    SERVER [connection ESTABLISHED]
```

SYN FLOOD attack:

```
ATTACKER --SYN-->    SERVER (x10,000 from spoofed IPs)
ATTACKER <-SYN-ACK--  SERVER (server waits...)
ATTACKER X no ACK ever sent X
>> Server's connection table fills with HALF-OPEN connections
>> Real clients can't connect
```

Slowloris analogy: ordering food but speaking ONE WORD per minute — staff stuck waiting, can't serve others. Now imagine 1000 people doing this. Restaurant frozen.

Dev: Cloudflare 2023: 201M RPS HTTP/2 Rapid Reset attack. GitHub 2018: 1.35 Tbps memcached amplification. AWS Shield auto-mitigates volumetric. Express.js single-thread vulnerable to Slowloris-style.

4.3 DoS vs DDoS

DoS:
[Attacker]
|
flood
v
[VICTIM]

DDoS:
[Commander]
|
+---+---+---+
v v v v
[bot][bot][bot]... (BOTNET)
| | |
v v v
[VICTIM]

Criteria	DoS	DDoS
Source	Single (one machine/IP)	Multiple (botnet)
Complexity	Simple	Complex (coordination)
Volume	Lower	Significantly higher
Detection	Easier (block 1 IP)	Harder (1000s of IPs)
Impact	Limited	Severe, can overwhelm any target

Dev: DoS = one user spamming /login → rate-limit by IP. DDoS = 50,000 IoT devices (Mirai botnet) hitting you → need Cloudflare/AWS Shield. Manual IP-blocking impossible.

4.4 MITM — Man-in-the-Middle

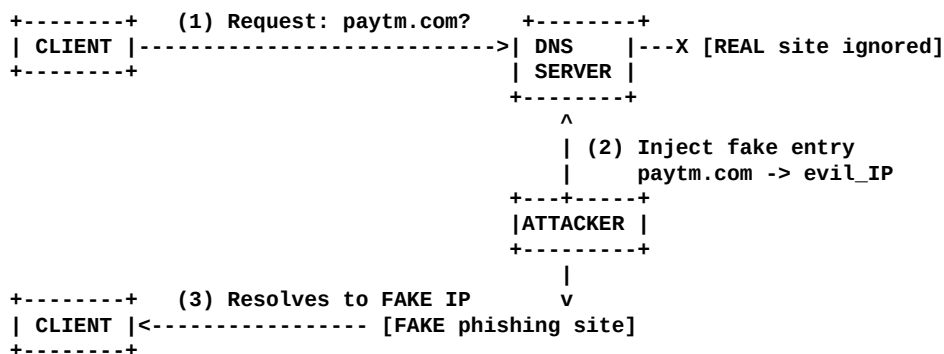
Attacker secretly intercepts/relays comms between two parties. Aka 'on-path' / 'adversary-in-the-middle'. Acts as proxy — neither party knows.

★ **HOOK: 4 types = ADHE: ARP, DNS, HTTPS-strip, Evil twin**

Type	How it works
ARP Spoofing	Links attacker MAC to legit IP on LAN → traffic flows through attacker
DNS Spoofing	Modifies DNS records → users redirected to fake site
HTTPS Spoofing / SSL Stripping	Downgrades HTTPS to HTTP → reads plaintext
Evil Twin Wi-Fi	Fake hotspot ('Starbucks_Free') → users connect, all traffic captured

Dev: ARP spoof on coffee shop WiFi. DNS spoof: paytm.com → paytm-fake.com. SSL strip: bank login captured. Evil twin: airport free WiFi traps.

4.5 DNS Spoofing — 3 steps



Phonebook analogy: DNS = internet's phonebook. If someone edited it to point Pizza Hut's number to a scam, you'd happily call — never knowing.

Dev: Defenses: DNSSEC (signs DNS records cryptographically), DNS-over-HTTPS (DoH) encrypts DNS queries themselves. Modern browsers support both.

Yap: 'DNS spoofing exploits trust in name resolution. Attacker injects malicious entries into DNS cache — users requesting a legit domain get the attacker's IP, often a phishing mirror. Defenses: DNSSEC cryptographically signs records; DoH encrypts the resolution itself.'

5. Defenses: Firewalls, IPS/IDS, VPN, WPA

5.1 Firewalls — First Line of Defense

Bouncer at the only club entrance. Forces ALL traffic through a single checkpoint, monitored against predefined rules.

★ **HOOK: Why firewalls = PBPCM: Prevent unauthorized access, Block malicious traffic, Protect sensitive info, Control network usage, Mitigate insider risks**

6 Types of Firewall Technology

Type	What it does	Dev Example
Packet-Filtering	Inspects headers (IP/port)	AWS Security Groups
Stateful Inspection	Tracks connection state	Linux iptables w/ conntrack
Proxy Firewall	Intermediary fetching content	Squid proxy, corporate filter
Next-Gen (NGFW)	DPI + app-aware + threat-intel	Palo Alto, Fortinet
Cloud Firewall	Firewall-as-a-service	Cloudflare WAF, AWS WAF
Hardware vs Software	Physical vs OS-level	Windows Defender FW, ufw

5.2 NGFW — Next-Generation Firewall

Goes beyond packet filtering with deep packet inspection, app awareness, threat intelligence. Bouncer + metal detector + facial recognition combined.

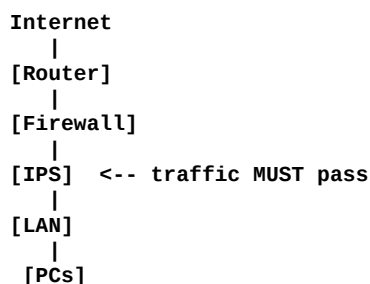
★ **HOOK: Features = AID-TDU**

Feature	What it does
App Awareness & Control	Identifies/controls apps regardless of port
IPS	Auto-blocks malicious traffic
DPI (Deep Packet Inspection)	Analyzes packet CONTENT, not just headers
Threat Intel Integration	Live feeds for latest threats / malicious IPs
SSL/TLS Decryption	Inspects encrypted traffic for hidden threats
User Identification	Policies based on users/groups (AD), not just IPs

NGFW vs Traditional: Traditional = L3+L4 (IPs and ports). NGFW = ALL layers including L7 (application). NGFW catches SSH tunneled over port 443; traditional doesn't.

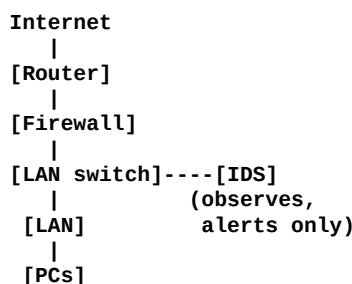
5.3 IPS vs IDS — THE EXAM FAVORITE

IPS (PREVENTION) - INLINE



IPS = Cop on road (pulls you over)

IDS (DETECTION) - SIDE



IDS = CCTV camera (records)

Aspect	IPS	IDS
Position	INLINE (in data path)	Out of band (on side)
Action	BLOCKS / prevents	ONLY ALERTS — passive
Mode	Active	Passive
Performance	Can slow network	Zero performance impact
Layer	L2, after firewall	Out of band

★ **HOOK: IPS = Prevent (Inline). IDS = Detect (on the Side).**

IPS Actions = ADDR: Alert admins, Drop traffic, Deny source, Reset connection.

Dev: IPS = Snort inline, Cisco Firepower. IDS = Snort detection mode, Suricata, AWS GuardDuty (alerts only). SIEM (Splunk, ELK) consumes IDS alerts.

5.4 VPN — Virtual Private Network

Creates a secure encrypted tunnel between your device and internet. Hides activity, masks IP. Underground tunnel from Mumbai to NY analogy.

★ **HOOK: How VPNs work = ETM: Encryption + Tunneling + Masking IP**

Mechanism	Effect
Encryption	Data unreadable except to you and VPN server
Tunneling	Routes traffic through secure server — ISP/hackers see only the tunnel
Masking IP	Replaces local IP with VPN server's IP — hides location

Benefits (PRS): Public Wi-Fi security, Remote work, Streaming/Privacy.

Built on: IPSec (Tunnel mode) for enterprise; SSL/TLS (OpenVPN-style) for consumer.

Dev: Consumer: NordVPN, ExpressVPN, ProtonVPN. Modern dev: Tailscale, WireGuard. Corporate: AWS Client VPN, Cisco AnyConnect.

5.5 WPA — Wi-Fi Protected Access

Standard	Year	Notes
WPA	2003	Draft IEEE 802.11i; uses TKIP; intermediate stopgap by Wi-Fi Alliance
WPA2	2004	Full IEEE 802.11i (or 802.11i-2004); more secure & complex; widely deployed
WPA3	2018+	Modern; SAE handshake; brute-force resistant (bonus, not in slides)

WPA full form: Wi-Fi Protected Access. **Body:** Wi-Fi Alliance. **Std:** IEEE 802.11i.

WARNING: Don't confuse WPA (Wi-Fi security) with **WAP** (Wireless Application Protocol — old 2G/3G mobile internet). Page 50 of slides talks about WAP, not WPA.

5.6 Defense Layering — The Big Picture

```
Internet
|
[Router]
|
[Firewall / NGFW]
|
[IPS inline] ----- (blocks attacks)
|
[LAN] ----- [IDS on side] (observes, alerts)
|
[PCs]
```

Remote users connect via VPN tunnel (IPSec / TLS)

Wi-Fi clients secured by WPA2 / WPA3

All web traffic encrypted via HTTPS (TLS)

Identity via Auth (know/are/have) + Access Control (DAC/MAC/RBAC/ABAC)

Yap: 'A modern enterprise stack: NGFW at perimeter for L7 visibility, IPS inline for active blocking, IDS out of band for forensic alerting, IPSec/TLS-based VPN for remote access, and WPA2/WPA3 securing wireless. Identity is verified through multi-factor auth combining knowledge, possession, and biometric factors, with RBAC or ABAC enforcing fine-grained authorization.'

6. Final 5-Minute Cheat Sheet

Acronym Speed Run

Topic	Acronym
Security Principles	CIA-AAN-Z
Threats	I'M FI (Interception/Modification/Fabrication/Interruption)
Threat Types	1 Passive (Interception), 3 Active (rest)
TLS Architecture	HRA — Handshake/Record/Alert
TLS Workflow	CSKSF — Client Hello/Server Hello/Key Exch/Session Keys/Finished
HTTPS Port	443 (HTTP=80)
IPSec Components	AESI — AH/ESP/SA/IKE
IPSec Modes	Transport (host-to-host), Tunnel (VPN, full packet)
Auth Factors	Know / Are / Have
Access Control	DMRA-R — DAC/MAC/RBAC/ABAC/RuBAC
DoS Types	VPA — Volumetric/Protocol/App-layer
DoS vs DDoS	Single source vs Botnet
MITM Types	ADHE — ARP/DNS/HTTPS-strip/Evil twin
NGFW Features	AID-TDU
IPS Actions	ADDR — Alert/Drop/Deny/Reset
IPS vs IDS	Inline+Block vs Side+Alert
VPN	ETM — Encrypt/Tunnel/Mask IP
WPA	Wi-Fi Protected Access; 2003=WPA; 2004=WPA2; IEEE 802.11i

CIA Mapping (memorize!)

Threat	CIA Broken
Interception (PASSIVE)	Confidentiality
Interruption	Availability
Modification	Integrity (+Availability)
Fabrication	Authentication (+Availability)

Killer Yapping Lines (drop these)

Yap: 'Only Interception is PASSIVE — it just listens. The other three are ACTIVE because they alter the data or system.'

Yap: 'TLS uses asymmetric crypto in the handshake to securely exchange the pre-master secret, then switches to faster symmetric session keys for the actual data — best of both worlds.'

Yap: 'IPSec Tunnel mode wraps the entire IP packet inside a new encrypted packet, hiding even the original source/destination — this is why VPNs use it.'

Yap: 'IPS sits inline and actively blocks; IDS sits out of band and only alerts. Cop vs CCTV.'

Yap: 'NGFW operates at all OSI layers including L7, while traditional firewalls stop at L3/L4. This means an NGFW can block SSH-over-port-443 tunnels that traditional firewalls miss.'

Yap: '2FA combines two DIFFERENT factor categories — password (know) + OTP (have), or password + fingerprint (are). Two passwords don't count.'

You got this, Didrik. Go ace it.